SISTEMA ELEITORAL VERIFICÁVEL

Registro público em blockchain permissionada
+ Cartão do eleitor com PUF + Criptografia pós-quântica

Documento Técnico v2.0

Rascunho aberto para revisão por desenvolvedores,
criptógrafos, engenheiros de hardware e auditores

Outubro de 2026

Evolução da proposta original v1.0 (outubro de 2025)

Este documento é uma proposta de pesquisa e engenharia. Não é um sistema pronto, não foi auditado e foi escrito para ser questionado, atacado e melhorado.

Autor / contato: [preencher] | Repositório: [preencher] | Licença sugerida: CC BY-SA 4.0 (texto)

Como ler este documento

Este texto expande a proposta original (v1.0) em um documento que um desenvolvedor, um criptógrafo ou um engenheiro de hardware possa abrir, entender o que se pretende construir, descobrir onde estão os problemas difíceis e começar a trabalhar. Ele foi escrito com três compromissos:

- **Honestidade técnica.** Onde a v1.0 prometia mais do que a tecnologia entrega (por exemplo, “inviolável”, “impossível de clonar”, “zk-SNARKs pós-quânticos”), este documento corrige e explica por quê. O Apêndice A lista cada correção.
- **Problemas abertos à vista.** Há uma seção inteira (16) com o que ainda não sabemos resolver. Um projeto eleitoral só merece confiança se expuser suas fraquezas antes dos outros.
- **Abertura.** Especificação, código, decisões de projeto e relatórios de auditoria devem ser públicos desde o primeiro dia. Nenhum token financeiro, nenhuma criptomoeda, nenhum modelo de negócio atrelado ao voto.

> **Status**
> Proposta de pesquisa e engenharia. Não é um sistema pronto, não foi auditado e não faz juízo sobre o sistema eleitoral em uso. Qualquer adoção em eleições oficiais dependeria de decisão da Justiça Eleitoral e de mudanças legais, fora do escopo técnico deste texto.

Sumário

Como ler este documento 2

Sumário . . . 2

1. Resumo executivo 4

O que a proposta tem de forte . . . 4

O que ainda precisa ser provado . . . 4

2. Contexto e motivação 4

3. Princípios de projeto 5

4. Propriedades de segurança desejadas 5

5. Modelo de ameaças 6

6. Arquitetura de referência 6

Fluxo geral . . . 7

7. Camada 1 – Registro público (blockchain permissionada) 7

7.1 Para que serve e para que não serve . . . 7

7.2 Decisões de projeto . . . 7

7.3 Escala . . . 7

8. Camada 2 – Cartão do eleitor (PUF + Secure Element) 8

8.1 Componentes . . . 8

8.2 Ressalvas honestas sobre PUF . . . 8

8.3 Ciclo de vida do cartão 8

9. Camada 3 – Criptografia pós-quântica 9

Transição e agilidade 9

10. Protocolo de votação passo a passo 10

10.1 Estruturas de dados 10

10.2 Fases 10

10.3 Perda de cartão e voto duplo (problema difícil) 10

10.4 Esboço do passo de votação 11

10.5 Invariantes (“a conta fecha”) 11

11. Apuração e regras por cargo 11

12. A urna 12

13. Verificabilidade e auditoria pública 12

13.1 Desafio de Benaloh 12

13.2 Trilha em papel (opcional) 12

14. Acessibilidade, contingência e operação 13

15. Governança, cerimônias e transparência 13

16. Riscos e problemas em aberto 13

17. Trabalhos relacionados 14

18. Roteiro de desenvolvimento 14

19. Equipe e como contribuir 15

Perfis necessários 15

Regras do projeto 15

Primeiras tarefas concretas 15

Apêndice A – O que mudou em relação à v1.0 e por quê 16

Apêndice B – Estimativas de escala (hipóteses a validar) 16

Apêndice C – Glossário 17

Apêndice D – Referências para estudo 17

1. Resumo executivo

A proposta combina três ideias para construir um sistema de votação presencial **verificável de ponta a ponta**: (1) um registro público e imutável dos votos cifrados e das provas de que cada um é válido e único; (2) um cartão inteligente do eleitor com chave protegida em hardware e função fisicamente não clonável (PUF); (3) criptografia resistente a computadores quânticos, para que o sigilo do voto dure décadas.

A votação continua **presencial, na seção eleitoral, em cabine**. O que muda é o que o sistema produz: além do resultado, ele publica evidências matemáticas que qualquer pessoa, universidade ou veículo de imprensa pode verificar com software próprio, sem precisar confiar em quem operou a urna.

O que a proposta tem de forte

- Unicidade do voto garantida por mecanismo criptográfico, além da lista de presença.
- Sigilo do voto separado da identidade do eleitor por construção (credencial anônima), e não por promessa.
- Contagem verificável: a soma publicada pode ser recalculada por qualquer um a partir dos votos cifrados públicos.
- Camadas independentes: falha em uma (por exemplo, urna comprometida) é detectável pelas outras (desafio de Benaloh, trilha em papel opcional, auditoria por amostragem).

O que ainda precisa ser provado

- Que provas de conhecimento zero pós-quânticas e cifras homomórficas de reticulados aguentam a escala de ~155 milhões de eleitores e 5 cargos.
- Que PUF + secure element + biometria funcionam em cartões baratos, duráveis e acessíveis a toda a população.
- Que a verificação pública é simples o bastante para que a confiança realmente aumente, e não apenas mude de lugar.

2. Contexto e motivação

A v1.0 afirmava que o sistema atual “não permite auditoria matemática pública”. Para um documento técnico, vale um enquadramento mais preciso, que é também mais difícil de refutar: o sistema em uso possui mecanismos de verificação — entre eles o Boletim de Urna impresso e publicado por seção, a zerésima, o teste de integridade (votação paralela), a lacração e assinatura digital dos programas e os Testes Públicos de Segurança.

O que o sistema atual **não oferece** é *verificabilidade criptográfica de ponta a ponta*: um cidadão não consegue, sozinho e sem confiar no software e no hardware da urna, verificar matematicamente que (a) seu voto foi registrado como ele o emitiu e (b) o total publicado corresponde exatamente aos votos registrados. Essa é a lacuna que a proposta quer endereçar, sem partir da premissa de que o sistema atual falhou.

> **Recomendação de enquadramento**
> Apresentar o projeto como “mais uma camada de evidência pública, independente de software”, e não como substituição por algo “inviolável”. É mais honesto, tecnicamente defensável e menos sujeito a polarização.

3. Princípios de projeto

1. **Nenhuma entidade única** consegue, sozinha, alterar o resultado, quebrar o sigilo ou impedir a verificação.
2. **Verificar, não confiar:** toda afirmação do sistema vem com prova que terceiros checam com software próprio.
3. **Sigilo e verificabilidade juntos:** o eleitor confere seu voto sem poder prová-lo a outra pessoa (resistência a compra e coerção).
4. **Defesa em profundidade:** criptografia, hardware, procedimento presencial e auditoria por amostragem se cobrem mutuamente.
5. **Código e especificação abertos,** com builds reproduzíveis e decisões de projeto registradas publicamente.
6. **Simplicidade onde der:** cada componente complexo precisa justificar por que um mais simples não basta.
7. **Agilidade criptográfica:** algoritmos podem ser trocados sem refazer o sistema (a pós-quântica ainda está em evolução).
8. **Inclusão e contingência:** o sistema precisa funcionar para todos os eleitores e continuar funcionando sem energia ou internet na seção.
9. **Sem componente financeiro:** nada de token negociável, taxas ou incentivos econômicos no protocolo.

4. Propriedades de segurança desejadas

Propriedade	Significado	Como é atendida (resumo)
Elegibilidade	Só eleitor apto vota.	Credencial na árvore de eleitores aptos + habilitação presencial.
Unicidade	Cada eleitor vota uma vez por eleição.	Nullifier único por eleição; lista de presença independente.
Sigilo	Ninguém liga voto a eleitor.	Credencial anônima (prova de conhecimento zero); voto cifrado; cabine.
Integridade	Voto não é alterado depois de emitido.	Votos cifrados no registro público, assinados e encadeados.
Verificabilidade individual	Eleitor confere que seu voto foi gravado como pretendia.	Desafio de Benaloh + código de acompanhamento + (opcional) trilha em papel.
Verificabilidade universal	Qualquer um confere a soma final.	Soma homomórfica pública + decifração limiar com prova.
Resistência a coerção	Eleitor não consegue provar em quem votou.	Sem recibo transferível; cabine privada.
Disponibilidade	A eleição acontece mesmo com falhas.	Urna offline-first, lotes, contingência em papel.
Sigilo de longo prazo	Segredo sobrevive a computadores quânticos.	PQC nos cifrados e provas; modo híbrido na transição.
Soberania	Operação sob controle nacional.	Validadores institucionais brasileiros; hardware auditável.

5. Modelo de ameaças

Todo sistema eleitoral deve começar por quem o atacaria e como. Esta tabela é o ponto de partida e deve ser expandida na Fase 0 do roteiro.

Adversário	Capacidade	Objetivo	Mitigação principal
Eleitor malicioso	Tem cartão legítimo	Votar duas vezes ou vender o voto	Nullifier por eleição; cabine; sem recibo comprovável
Cartão clonado ou falso	Extração física de chaves	Votar como outra pessoa	Secure element certificado + PUF; revogação; limite de tentativas
Insider (mesário, técnico, fornecedor)	Acesso físico à urna ou ao software	Alterar votos ou vazar sigilo	Build reproduzível, attestation, lacre, logs, separação de funções
Urna comprometida	Software malicioso	Mostrar A na tela, gravar B	Desafio de Benaloh, votação paralela, trilha em papel opcional, auditoria por amostragem
Operadores de nós	Conluio de validadores	Censurar, reordenar, reescrever	BFT com validadores de instituições independentes; nós observadores públicos; âncoras externas de hash
Custodiantes de chaves	t de k em conluio	Decifrar votos individuais	Decifração limiar, instituições diversas, cerimônia pública, HSM
Atacante de rede / DoS	Derrubar conectividade	Impedir votação ou apuração	Offline-first, lotes assinados, múltiplos canais de transmissão
Adversário quântico futuro	Quebra RSA/ECC; coleta hoje para decifrar depois	Quebrar sigilo retroativamente	PQC (e modo híbrido); minimizar segredos de longo prazo
Coerção em massa	Exige prova de voto	Comprar ou forçar votos	Resistência a recibo; cabine; sem prova transferível
Campanha de desinformação	Alegações falsas de fraude ou falha	Minar a confiança	Verificador público simples; transparência radical; relatórios de auditoria

6. Arquitetura de referência

A arquitetura mantém os três pilares da v1.0, mas redefine o papel de cada um para resolver os problemas apontados no Apêndice A.

Componente	Função	Observação
Autoridade de registro	Emite cartões, registra compromissos de credencial, publica a raiz da árvore de eleitores aptos.	Sabe quem recebeu qual cartão, mas não consegue ligar o voto ao eleitor.
Cartão do eleitor	Guarda a chave secreta no secure element; autentica-se por PUF; biometria opcional no próprio cartão.	A chave nunca sai do chip.
Urna	Habilita o eleitor, coleta o voto na cabine, cifra, gera provas, assina o lote.	Hardware aberto e auditável; boot seguro; attestation.
Registro público (blockchain permissionada)	Quadro de avisos append-only: raiz de eleitores, nullifiers, cédulas cifradas, provas, lotes, resultados.	Validadores institucionais; qualquer pessoa roda nó observador.
Custodiantes de chave	Guardam fragmentos da chave de decifração da apuração (limiar t-de-k).	Instituições independentes.

Componente	Função	Observação
Módulo de apuração	Soma cifrada por seção, decifração com prova, aplicação das regras de cada cargo.	Versionado; versão aprovada publicada antes da eleição.
Verificador público	Programa aberto que reconfere tudo: provas, unicidade, soma, decifração.	CLI e versão web; várias implementações independentes.

Fluxo geral

1. Emissão	2. Congelamento	3. Habilitação	4. Votação	5. Publicação	6. Apuração	7. Auditoria
Cartão + compromisso	Raiz Merkle assinada	Mesário + cartão	Cabine, cifra, prova	Lote no registro	Soma + decifração	Verificação pública

7. Camada 1 – Registro público (blockchain permissionada)

7.1 Para que serve e para que não serve

O registro serve como **quadro de avisos público, append-only e com consenso entre instituições que não confiam umas nas outras**. Ele garante que todos vejam os mesmos dados na mesma ordem e que nada seja apagado ou reescrito depois.

Ele **não** garante que a urna mostrou a opção certa ao eleitor, que o hardware está íntegro, que o software foi o aprovado nem que o eleitor não foi coagido. Para isso existem as outras camadas.

7.2 Decisões de projeto

- **Rede permissionada:** validadores são instituições (Justiça Eleitoral, Ministério Público, universidades públicas, OAB, entidades científicas, partidos, imprensa credenciada). Qualquer pessoa roda **nó observador**: baixa, sincroniza e verifica tudo, mas não participa do consenso.
- **Consenso BFT com finalidade determinística** (famílias Tendermint/HotStuff), tolerando até um terço de validadores faltosos ou maliciosos. Sem mineração, sem prova de trabalho, sem taxas.
- **Conteúdo:** apenas compromissos, nullifiers, cédulas cifradas, provas, assinaturas e resultados. **Nunca** identidade de eleitor.
- **Âncoras externas:** raízes de hash publicadas periodicamente em canais independentes (Diário Oficial, jornais, outras redes públicas) para dificultar reescrita da história.
- **Lógica mínima on-chain:** validar prova, rejeitar nullifier repetido, registrar lotes. Regras complexas de apuração ficam em código aberto e reproduzível, com prova pública do resultado, e não em contratos inteligentes extensos (contratos têm histórico de bugs).

> **Pergunta aberta: é preciso uma blockchain?**
> O que realmente se precisa é um log público append-only com testemunhas independentes (como os logs de transparência de certificados, baseados em árvores de Merkle). Uma blockchain BFT é uma forma de obter isso; um log com múltiplas testemunhas pode ser mais simples. A Fase 0 deve comparar as duas opções por escrito e decidir com base em requisitos, não em preferência por tecnologia.

7.3 Escala

Com ~155 milhões de eleitores e voto das 8h às 17h (9 horas), 100% de comparecimento exigiria média de ~4,8 mil cédulas por segundo, com picos maiores. Como a urna opera **offline-first** e envia lotes ao

fechar, a carga real é de ingestão em lote, não de transações em tempo real. O volume de dados depende fortemente de como o voto é codificado (ver Apêndice B).

8. Camada 2 – Cartão do eleitor (PUF + Secure Element)

8.1 Componentes

- **Secure element (SE) certificado** (nível Common Criteria elevado): guarda a chave privada, executa as assinaturas, resiste a ataques físicos e de canal lateral. A chave nunca sai do chip.
- **PUF (Physical Unclonable Function):** gera um segredo único derivado das variações microscópicas de fabricação do silício. Usado como raiz de confiança do dispositivo, não como único fator.
- **Biometria opcional com match-on-card:** a digital é lida e comparada dentro do cartão; o modelo biométrico nunca sai dele.
- **Interface por contato ou campo próximo** com medidas contra ataques de retransmissão (relay).

8.2 Ressalvas honestas sobre PUF

- “Impossível de clonar” é exagero; o correto é “muito difícil de clonar fisicamente”. PUFs fracos (por exemplo, tipo arbiter) sofreram ataques de modelagem por aprendizado de máquina.
- A resposta de uma PUF é **ruidosa** e varia com temperatura, tensão e envelhecimento. Usa-se extrator difuso (fuzzy extractor) com dados auxiliares e correção de erros para derivar uma chave estável.
- Para uma vida útil de anos, é preciso testar envelhecimento e condições extremas (calor, umidade) em todo o território nacional.
- Rodar assinatura pós-quântica em chips restritos é viável, mas exige mais memória que RSA/ECC; deve ser medido em hardware real (ver riscos).

8.3 Ciclo de vida do cartão

Etapa	O que acontece	Ponto crítico
Emissão	A chave é gerada dentro do cartão; só o compromisso público sai. A autoridade registra o compromisso associado ao eleitor.	Cerimônia de emissão auditável; ninguém vê a chave.
Ativação	Eleitor ativa o cartão (biometria opcional).	Evitar ativação por terceiros.
Uso	Na seção, o cartão responde ao desafio da urna e gera a prova de elegibilidade.	Limite de tentativas; tempo de resposta curto.
Perda ou roubo	Revogação do compromisso antigo e emissão de novo.	Não permitir voto duplo entre cartão antigo e novo (ver 10.3).
Fim de vida	Renovação periódica; destruição segura.	Custo e logística para ~155 milhões de cartões (a estimar).

Alternativa a avaliar

A Justiça Eleitoral já mantém cadastro biométrico de eleitores. Antes de projetar 155 milhões de cartões novos, avaliar uma variante em que o **dispositivo de habilitação** da seção faz a autenticação biométrica e o cartão tem papel menor. Custo, durabilidade e acessibilidade devem pesar na decisão.

9. Camada 3 – Criptografia pós-quântica

Computadores quânticos suficientemente grandes quebrariam RSA e curvas elípticas (algoritmo de Shor). Para voto, o risco principal é **“colher agora, decifrar depois”**: um adversário guarda hoje dados cifrados para decifrar no futuro e revelar votos individuais. Por isso o sigilo precisa de proteção pós-quântica desde o início.

Função	Primitiva recomendada	Observação
Assinatura de uso geral	ML-DSA (FIPS 204, ex-CRYSTALS-Dilithium)	Boa relação segurança/desempenho; assinaturas de alguns KB.
Assinatura conservadora (raízes de confiança)	SLH-DSA (FIPS 205, ex-SPHINCS+)	Baseada só em hash; assinaturas grandes; premissas mínimas.
Assinatura compacta	FN-DSA (Falcon), padrão em elaboração pelo NIST	Verificar o estado do padrão; implementação delicada (ponto flutuante).
Troca/encapsulamento de chave	ML-KEM (FIPS 203, ex-CRYSTALS-Kyber)	Padrão publicado pelo NIST em 2024.
KEM de reserva	HQC (selecionado pelo NIST em 2025 para padronização)	Diversidade: baseado em códigos, não em reticulados.
Hash	SHA-3 ou SHA-256, saídas de 256 bits ou mais	Margem contra o algoritmo de Grover.
Simétrica	AES-256 ou ChaCha20-Poly1305	Chaves de 256 bits.
Provas de conhecimento zero	zk-STARKs (baseados em hash) ou provas de reticulados	**SNARKs com emparelhamentos (Groth16, PLONK-KZG) NÃO são pós-quânticos.**
Cifra com soma homomórfica	Esquemas de reticulados (BFV/BGV)	ElGamal clássico não é pós-quântico. Decifração limiar em reticulados é área de pesquisa ativa.

Correção importante em relação à v1.0
A v1.0 citava zk-SNARKs como parte da camada pós-quântica. SNARKs usuais dependem de emparelhamentos em curvas elípticas, quebráveis por computador quântico. Para manter a promessa pós-quântica, usar STARKs ou provas baseadas em reticulados. Os nomes oficiais dos padrões são ML-KEM e ML-DSA (FIPS 203 e 204, agosto de 2024).

O que PQC não resolve
Criptografia pós-quântica protege contra um tipo de ataque matemático. Ela não protege contra bug de software, urna adulterada, insider, coerção, falha de procedimento ou hardware comprometido. Por isso o documento fala em sistema **verificável e resiliente**, e não “inviolável”.

Transição e agilidade

- Usar **modo híbrido** (clássico + pós-quântico) onde fizer sentido, para não depender de uma única família de premissas.
- Separar algoritmo de protocolo: trocar ML-DSA por outro padrão deve exigir mudança de parâmetros, não redesenho.

10. Protocolo de votação passo a passo

10.1 Estruturas de dados

Estrutura	Conteúdo
Credencial	Chave secreta sk dentro do cartão; compromisso público C = Commit(sk).
Árvore de eleitores aptos	Árvore de Merkle com todos os compromissos C; raiz R assinada e publicada antes da eleição.
Nullifier	N = H(sk, id_eleição). Prova que “esta credencial já votou” sem revelar qual.
Cédula	5 contêineres cifrados (um por cargo), cada um com prova de boa formação (exatamente uma opção válida: candidato, legenda, branco ou nulo), mais N e a prova de elegibilidade.
Lote da urna	Conjunto de cédulas da seção, assinado pela urna (ML-DSA), com attestation e logs.

10.2 Fases

1. **Cerimônia de configuração:** geração da chave da eleição com divisão em fragmentos entre custodiantes (limiar t-de-k); publicação de parâmetros, hashes dos binários e especificações.
2. **Emissão:** cartões gerados; compromissos registrados.
3. **Congelamento:** raiz R da árvore assinada e publicada.
4. **Habilitação na seção:** mesário identifica o eleitor (lista de presença independente); cartão responde ao desafio; urna verifica autenticidade do cartão.
5. **Votação na cabine:** o eleitor escolhe nos 5 cargos na sequência, revisa e aperta CONFIRMA TUDO. A urna cifra os 5 votos *em uma única cédula atômica*, gera as provas e, com o cartão, a prova de elegibilidade e o nullifier. Não existe voto parcial.
6. **Verificação individual (opcional):** desafio de Benaloh (ver 13) e código de acompanhamento da cédula.
7. **Fechamento:** a urna encerra o lote, assina, imprime/gera o Boletim de Urna criptográfico e guarda tudo em mídia segura.
8. **Publicação:** lote enviado ao registro por rede ou por mídia física (contingência).
9. **Validação pública:** qualquer verificador confere provas, unicidade de nullifiers e contagem.
10. **Apuração:** soma homomórfica por seção e cargo; decifração limiar com prova; aplicação das regras de cada cargo.
11. **Auditoria:** verificação independente, amostragem física, relatório público.

10.3 Perda de cartão e voto duplo (problema difícil)

Se um cartão é perdido e reemitido, o cartão antigo não pode votar depois do novo (ou vice-versa). Como o nullifier depende da chave secreta, a autoridade não sabe qual nullifier o cartão antigo geraria. Duas direções, que podem ser combinadas:

- **Opção A – credencial anônima:** revogar o compromisso antigo na árvore antes da eleição; se a perda ocorrer no dia, aplicar a Opção B.
- **Opção B – habilitação presencial identificada:** a lista de presença da seção (como hoje) impede que a mesma pessoa seja habilitada duas vezes; a cédula permanece anônima. É uma camada independente da criptografia.

10.4 Esboço do passo de votação

```
VOTAR(urna, cartao, escolhas[5]):
  1. cartao.autenticar(desafio_PUF)            // prova que é cartão genuíno
  2. para cada cargo i em 1..5:
       ct[i]  = Cifrar(chave_eleicao, escolhas[i])      // PQ, soma homomórfica
       pf[i]  = ProvaBoaFormacao(ct[i])                 // uma opção válida
  3. N   = cartao.nullifier(id_eleicao)
     pe  = cartao.ProvaElegibilidade(raiz_R, N)         // conhecimento zero PQ
  4. cedula = (ct[1..5], pf[1..5], N, pe)
  5. Benaloh: eleitor pode DESAFIAR -> urna revela aleatoriedade,
     cedula é descartada; eleitor refaz o voto.
  6. CONFIRMA -> urna apaga a aleatoriedade; guarda cedula no lote.
  7. mostra codigo_acompanhamento = Hash(cedula)
```

10.5 Invariantes (“a conta fecha”)

A v1.0 propunha que 155M tokens queimados correspondem a 155M×5 votos. Aqui isso vira um conjunto de invariantes verificáveis publicamente:

Invariante	Quem verifica
Nº de nullifiers distintos = nº de cédulas aceitas	Qualquer verificador
Para cada cargo, total de votos (candidatos + legenda + branco + nulo) = nº de cédulas	Qualquer verificador (soma cifrada + decifração com prova)
Nº de cédulas da seção = nº de habilitações na lista de presença da seção	Auditoria cruzada, independente da criptografia
Toda cédula tem prova de elegibilidade e de boa formação válidas	Qualquer verificador
Soma decifrada = decifração do total cifrado público	Qualquer verificador (prova de decifração limiar)

11. Apuração e regras por cargo

Cargos majoritários (Presidente, Governador, Senador) e **proporcionais** (Deputado Federal e Estadual) seguem a legislação eleitoral vigente, incluindo segundo turno quando exigido e, nos proporcionais, quociente eleitoral, quociente partidário e distribuição de sobras. Duas decisões de projeto:

- **A regra é parâmetro, não código fixo.** O módulo de apuração é versionado, tem especificação em linguagem natural e testes, e a versão aprovada é publicada antes da eleição. Mudanças legais viram nova versão, não remendo.
- **Apuração por seção** preserva a lógica atual de resultados por seção, mas o somatório cifrado só é decifrado depois do fechamento e com participação de t custodiantes. Seções muito pequenas expõem padrões de voto (problema já existente hoje); avaliar agregação mínima.

> **Desafio de escala em proporcionais**
> Em cargos com centenas ou milhares de candidatos, codificar o voto como vetor “um-quente” (uma posição por candidato) gera cédulas grandes e provas pesadas. Técnicas como empacotamento de vários valores em um único texto cifrado (batching em BFV/BGV) e codificação por índice com prova de intervalo precisam ser avaliadas. Isto é, provavelmente, o maior problema de engenharia de desempenho do projeto.

12. A urna

- **Hardware aberto e auditável**, com lista de componentes pública e cadeia de suprimentos rastreável.
- **Boot seguro e attestation remota:** a urna prova, por assinatura, qual software está rodando. O hash do build é comparável ao publicado.
- **Builds reproduzíveis:** qualquer pessoa compila o código-fonte e obtém exatamente o mesmo binário.
- **Superfície mínima:** sistema operacional enxuto, sem rede durante a votação, portas físicas lacradas e monitoradas.
- **O que se vê é o que se cifra:** o caminho tela → cifra deve ser o mais curto possível e verificável pelo desafio de Benaloh.
- **Registro de eventos assinado e encadeado** (logs imutáveis), com carimbo de tempo.
- **Resistência a adulteração física:** sensores de abertura, lacres, inspeção.
- **Offline-first:** a votação não depende de conectividade; o envio acontece depois, por rede ou mídia física.

13. Verificabilidade e auditoria pública

Quem	O que verifica	Como
Eleitor	Seu voto foi cifrado como pretendia (*cast-as-intended*) e entrou no registro (*recorded-as-cast*).	Desafio de Benaloh na cabine; código de acompanhamento consultável depois.
Qualquer cidadão	As provas são válidas, os nullifiers são únicos e a soma bate.	Verificador aberto (CLI e web).
Universidades, imprensa, partidos	Reprodução completa da apuração; revisão do código; build reproduzível.	Nós observadores e várias implementações independentes do verificador.
Auditores independentes	Cerimônias, hardware, cadeia de suprimentos; amostragem de seções.	Auditoria com limitação de risco (RLA) comparando papel e registro.

13.1 Desafio de Benaloh

Antes de confirmar, o eleitor pode **desafiar** a urna: ela revela como cifrou aquela cédula, o eleitor (ou um app independente) confere se a cifra corresponde à escolha, e a cédula é descartada; depois o eleitor vota de verdade. Uma urna que mentisse seria pega com probabilidade proporcional ao número de eleitores que desafiam. Como a cédula desafiada é descartada, nada do que foi revelado prova em quem o eleitor votou na cédula efetiva.

13.2 Trilha em papel (opcional)

A literatura recomenda uma trilha de papel verificada pelo eleitor como defesa independente de software. Sua adoção é decisão legal e política, fora do escopo técnico; o projeto deve funcionar com ela ou sem ela, e a especificação deve prever as duas configurações.

> **Cuidado com o recibo**
> O código de acompanhamento deve ser um hash da cédula cifrada com aleatoriedade apagada: serve para conferir que a cédula entrou no registro, mas não permite provar a terceiros em quem se votou.

14. Acessibilidade, contingência e operação

- **Acessibilidade:** leitura em voz, fones, interface em Libras, contraste e tamanho de fonte ajustáveis, ajuda de acompanhante, suporte a eleitores com baixa escolaridade ou analfabetos (candidato por foto e número).
- **Locais sem energia ou internet:** bateria, operação offline, transmissão posterior por mídia física lacrada.
- **Eleitores no exterior:** definir se a mesma arquitetura vale; remoto exigiria outro modelo de ameaça (coerção), fora do escopo desta versão.
- **Contingência:** cédula em papel como plano B, contabilizada no mesmo registro por procedimento específico.
- **Treinamento:** mesários, fiscais e eleitores; simulações públicas antes da eleição.
- **Falha de cartão:** procedimento de habilitação alternativa com registro auditável.

15. Governança, cerimônias e transparência

- **Separação de funções:** quem escreve o código, quem constrói o binário, quem opera nós, quem guarda chaves e quem audita são entidades distintas.
- **Cerimônia pública de chaves:** geração da chave da eleição filmada e transmitida, com participação de observadores; fragmentos em HSM distribuídos entre custodiantes.
- **Controle de mudanças:** nenhum binário é alterado após a publicação do hash, salvo procedimento público.
- **Registro público de decisões** de projeto (ADR), com justificativa e alternativas descartadas.
- **Programa de recompensa por falhas** (bug bounty) e janelas de testes públicos de segurança com adversários reais.
- **Resposta a incidentes:** plano público, com critérios de quando e como suspender ou repetir etapas.
- **Conflitos de interesse declarados:** quem fornece hardware ou serviços não audita o próprio trabalho.

16. Riscos e problemas em aberto

#	Problema	Impacto	Direção de solução
1	Anonimato × identidade: queimar um token ligado ao eleitor, com data e hora públicas, pode ser correlacionado com a cédula.	Alto (sigilo)	Credencial anônima com nullifier e prova ZK; desacoplar tempo de publicação (lotes embaralhados).
2	Compra de voto e coerção: qualquer prova do voto é um recibo.	Alto	Sem recibo; Benaloh com descarte; cabine; avaliação formal.
3	PUFs: ruído, envelhecimento, ataques de modelagem; custo por cartão.	Médio–alto	Fuzzy extractor; SE certificado como defesa principal; testes de campo.
4	Desempenho de ZK pós-quântico e cifra homomórfica em ~155 M de cédulas × 5 cargos.	Alto	Protótipos e benchmarks; empacotamento; processamento por seção em paralelo.
5	Decifração limiar e provas de decifração em esquemas de reticulados (pesquisa recente).	Alto	Aliança com grupos acadêmicos; implementação de referência independente.
6	Urna comprometida que engana a tela e a cifra.	Alto	Benaloh, votação paralela, trilha em papel, attestation, RLA.

#	Problema	Impacto	Direção de solução
7	Cadeia de suprimentos de hardware (chips, firmware).	Alto	Múltiplos fornecedores, inspeção, amostragem destrutiva, firmware aberto quando possível.
8	Confiança: poucos verificam; a confiança migra para quem verifica.	Médio	Verificador simples; várias entidades independentes; transparência dos relatórios.
9	Complexidade: um sistema difícil de explicar pode reduzir a confiança pública.	Médio	Comunicação em camadas; analogias; demonstrações abertas.
10	DoS e disponibilidade no dia da eleição.	Alto	Offline-first; transmissão em lote; redundância.
11	Custo e logística de cartões, urnas e treinamento.	Médio	Estudo de viabilidade; pilotos em escala menor.
12	Enquadramento legal e adoção.	Alto	Diálogo com a Justiça Eleitoral, Congresso e sociedade; adoção só por decisão legítima.

17. Trabalhos relacionados

Sistema / técnica	O que traz	Lição para este projeto
Helios	Votação verificável via web (Adida, 2008), cifra homomórfica/mixnet.	Bom para eleições de baixo risco; remoto, logo coerção é problema.
ElectionGuard (código aberto)	Verificabilidade de ponta a ponta com cifra homomórfica e prova de decifração.	Referência prática de pipeline verificável; criptografia clássica.
Prêt à Voter, Scantegrity, STAR-Vote	Esquemas verificáveis presenciais com cédulas e recibos.	Mostram trade-offs entre usabilidade e verificabilidade.
Sistema suíço (Swiss Post) – auditoria pública de 2019	Revisão pública encontrou falhas em provas do mixnet.	Validação de que abrir o código e convidar ataque funciona; exige tempo e rigor.
Estônia (i-Voting) e iVote (Nova Gales do Sul)	Voto remoto em produção; análises críticas independentes.	Voto remoto tem ameaças próprias; este projeto é presencial.
Semaphore e protocolos de nullifier	Identidade anônima com prova ZK e nullifier.	Base conceitual; usa criptografia clássica, precisa de versão pós-quântica.
Auditorias com limitação de risco (RLA)	Amostragem estatística comparando papel e registro eletrônico.	Complemento independente do software.
Sistema brasileiro atual	Boletim de Urna, zerésima, teste de integridade, TPS.	Pontos de partida e de comparação; integrar, não ignorar.

18. Roteiro de desenvolvimento

Durações são indicativas e dependem da equipe. A ordem importa mais que os prazos: **especificar e atacar no papel antes de construir**.

Fase	Entregáveis	Duração indicativa	Critério de saída
0. Especificação e modelo de ameaças	Spec formal, modelo de ameaças, comparação blockchain × log de transparência, escolha de primitivas.	3–6 meses	Revisão por ≥ 3 criptógrafos independentes; lista de problemas abertos atualizada.
1. Protótipo de protocolo (só software)	Emissão, nullifier, cédula cifrada com provas, soma e decifração limiar, verificador público.	6–9 meses	Simulação com 1 M de eleitores; verificador independente reproduz resultado.

Fase	Entregáveis	Duração indicativa	Critério de saída
2. Prova de conceito de hardware	Cartão com SE + PUF; urna protótipo com boot seguro e attestation.	9–12 meses	Testes de ambiente; medição de assinatura PQ no cartão; relatório de falhas.
3. Escala e robustez	Simulação em escala nacional; testes de falha; red team; bug bounty.	6–9 meses	Metas de desempenho atingidas; vulnerabilidades críticas corrigidas.
4. Auditoria formal e certificações	Verificação formal do protocolo (Tamarin/ProVerif ou similar); auditorias externas; certificação de hardware.	6–12 meses	Relatórios públicos sem pendências críticas.
5. Pilotos reais de baixo risco	Eleições de entidades (sindicatos, conselhos, universidades) com papel como referência.	contínuo	Resultados idênticos ao papel; feedback de usabilidade.

Observação
Qualquer uso em eleições oficiais depende de decisão legal e institucional, sobre a qual este projeto não tem controle e que deve ocorrer apenas após pilotos, auditorias e debate público.

19. Equipe e como contribuir

Perfis necessários

- Criptógrafos (PQC, provas de conhecimento zero, protocolos de votação).
- Engenheiros de sistemas distribuídos e consenso BFT.
- Engenheiros de segurança de hardware e sistemas embarcados (secure element, PUF, side-channel).
- Especialistas em direito eleitoral e administração de eleições.
- Pesquisadores de usabilidade e acessibilidade.
- Auditores de segurança e red team independentes.
- Comunicadores científicos para explicar o sistema ao público.

Regras do projeto

- Código sob licença livre (sugestão: Apache-2.0 ou AGPL-3.0) e especificação sob CC BY-SA 4.0.
- Todas as decisões, discussões técnicas e relatórios de auditoria públicos.
- Nenhum token financeiro, nenhuma venda de acesso, nenhuma exclusividade comercial sobre o protocolo.
- Convite explícito para ataques: quem encontrar falha é creditado.
- Documentação em português e inglês.

Primeiras tarefas concretas

1. Escrever o modelo formal do protocolo (Tamarin/ProVerif) para unicidade, sigilo e verificabilidade.
2. Implementar o nullifier com prova STARK e medir tempo e tamanho.
3. Benchmark de ML-DSA e ML-KEM em secure element ou smart card real.
4. Simulador de carga com 155 M de cédulas sintéticas para medir armazenamento e verificação.
5. Comparar codificações de voto (vetor um-quente × índice) quanto a tamanho de texto cifrado e custo de prova.
6. Estudo de usabilidade do desafio de Benaloh com eleitores reais.

7. Revisão jurídica preliminar: o que a lei vigente permite em um piloto.

Apêndice A – O que mudou em relação à v1.0 e por quê

v1.0 dizia	v2.0 diz	Motivo
“Inviolável”	Verificável e resiliente	Nenhum sistema é inviolável; promessas absolutas são o primeiro alvo de críticos e minam a credibilidade.
1 eleitor = 1 NFT soulbound, queimado ao votar	Credencial anônima (compromisso) + nullifier único por eleição	Queimar publicamente um token ligado à identidade pode ser correlacionado com a cédula e quebrar o sigilo que o documento promete.
zk-SNARKs para anonimato	zk-STARKs ou provas de reticulados	SNARKs com emparelhamentos não são pós-quânticos.
Dilithium e Kyber	ML-DSA (FIPS 204) e ML-KEM (FIPS 203)	Nomes oficiais após padronização do NIST em 2024.
PUF “impossível de clonar”	“Muito difícil de clonar”; PUF como raiz de confiança, não único fator	Existem ataques de modelagem; PUFs são ruidosas.
“Qualquer pessoa pode baixar um nó e auditar”	Qualquer pessoa roda nó observador; validadores são instituições	Esclarece quem participa do consenso e quem apenas verifica.
Apuração “em minutos” por contrato inteligente	Apuração verificável por prova pública; tempo a medir	Decifração limiar e provas têm custo; contratos extensos são arriscados.
“O sistema atual não permite auditoria”	O sistema atual tem mecanismos; falta verificabilidade ponta a ponta	Enquadramento mais preciso e menos polarizador.
Carta assinada “Satoshi Nakamoto”	Autor ou coletivo identificado	Pseudônimo famoso pode ser lido como brincadeira e reduz credibilidade perante ministros, cientistas e imprensa.
“Proposta oficial”, rodapé “Confidencial”	Aberta, sem alegação de caráter oficial	Um sistema que promete auditoria pública deve ser público; “oficial” só se for verdade.

Apêndice B – Estimativas de escala (hipóteses a validar)

Grandeza	Valor de referência	Comentário
Eleitores aptos	~155 milhões	Ordem de grandeza da proposta original.
Votos (5 cargos)	~775 milhões	155 M × 5.
Cédulas por segundo (100% comparecimento, 9 h)	~4,8 mil em média	155 M ÷ 32.400 s; picos maiores. Na prática, ingestão em lote.
Tamanho por cédula	A medir	Depende da codificação. Vetor um-quente grande sem empacotamento pode chegar a centenas de KB ou mais; com batching, pode cair para dezenas de KB.
Armazenamento total	Hipótese: de TB a dezenas de TB	155 M × tamanho da cédula; determinar após benchmark da Fase 1.
Tempo de verificação completa	A medir	Meta: verificação por seção em minutos, paralelizável.

Apêndice C – Glossário

Termo	Significado
Attestation	Prova assinada por hardware de qual software está em execução.
BFT	Tolerância a falhas bizantinas; consenso que funciona mesmo com parte dos participantes maliciosos.
Benaloh challenge	Técnica em que o eleitor pode desafiar a urna a revelar a cifra de uma cédula de teste, que é descartada.
BU	Boletim de Urna: resultado impresso da seção.
E2E-V	Verificabilidade de ponta a ponta.
Árvore de Merkle	Estrutura de hashes que permite provar que um item pertence a um conjunto com prova curta.
Mixnet	Rede de embaralhamento verificável que desliga entrada de saída.
Nullifier	Valor público derivado de segredo que impede reuso sem revelar quem usou.
PQC	Criptografia pós-quântica.
PUF	Função física não clonável: segredo derivado de variações do silício.
Receipt-freeness	Propriedade de o eleitor não conseguir provar em quem votou.
RLA	Auditoria com limitação de risco: amostragem estatística de papel contra registro eletrônico.
Secure element	Chip resistente a adulteração que guarda chaves e executa criptografia.
SNARK / STARK	Provas de conhecimento zero. STARKs usam apenas hash e são pós-quânticos; SNARKs usuais usam emparelhamentos e não são.
Threshold (limiar)	Esquema em que t de k participantes são necessários para decifrar.
VVPAT	Trilha em papel verificada pelo eleitor.
ZK	Conhecimento zero: prova de uma afirmação sem revelar o segredo.

Apêndice D – Referências para estudo

- NIST. FIPS 203 (ML-KEM), FIPS 204 (ML-DSA) e FIPS 205 (SLH-DSA), 2024; acompanhar o padrão FN-DSA e a seleção do HQC (2025).
- J. Benaloh. *Simple Verifiable Elections*, 2006.
- B. Adida. *Helios: Web-based Open-Audit Voting*, 2008.
- D. Bernhard et al. *Public Evidence from Secret Ballots*, 2017.
- P. Stark. Trabalhos sobre auditorias com limitação de risco (RLA).
- J. A. Halderman, V. Teague. *The New South Wales iVote System*, 2015.
- D. Springall et al. *Security Analysis of the Estonian Internet Voting System*, 2014.
- T. Haines, S. Lewis, O. Pereira, V. Teague. *How Not to Prove Your Election Outcome*, 2020 (análise do sistema Swiss Post).
- Documentação do ElectionGuard (código aberto).
- Literatura sobre PUFs e extratores difusos; relatórios de ataques de modelagem a PUFs fracos.
- Documentação oficial do TSE sobre o sistema eletrônico de votação (Boletim de Urna, Testes Públicos de Segurança).

Fim do documento. Contribuições, críticas e ataques são bem-vindos: o objetivo é que este texto seja substituído por versões melhores escritas por muita gente.